CLOUD-SECURITY-ASSURANCE

클라우드 도입 보안·아웃소싱·CSAP

연관 기출 · 128-2-2, 129-4-6, 130-4-3, 134-2-1, 130-3-6

한눈에 이해

사업자가 받은 인증과 이용자가 안전하게 설정·운영하는 일은 구분하여, 계약에 서 종료와 복구까지 확인합니다.

정의와 핵심 원리

클라우드 보안은 공유 책임 환경에서 데이터·신원·워크로드·관리면·연결망을 보호하고 제공자 위험을 관리하는 활동입니다. 공공 부문 이용은 CSAP 등 해당 제도와 보안성 검토·데이터 등급·서비스 계약을 함께 검토해야 합니다.

• 도입 전 업무, 정보 등급, 법적 이용 근거와 위험을 검토합니다. 결과에 따라 서비스 모델, 배치 방식, 데이터 저장 위치와 운영 책임을 정합니다. 설계할 때 망 연결, 인증·암호 키, 로그·백업, 관리자 접속, 취약점, 사고 통지와 공급망을 확인합니다. 구축 뒤 구성 검증·이관·복구·부하 시험을 통해 운영 전환을 판단합니다.

• 아웃소싱 계약에는 보호 목표와 접근 권한, 하도급, 사고 대응, 감사권, 가용성 측정, 복구, 데이터 반환·삭제 증빙과 계약 종료를 명시합니다. 제공자 장애·사업 중단, 가격, 종속과 국외 이전 위험도 살핍니다. 암호화 시 제공자가 가진 권한과 키의 소유·교체·복구 경로를 확인합니다.

• CSAP는 인증받은 서비스와 범위, 유효 상태를 확인합니다. IaaS의 인증 범위와 그 위에서 구동하는 SaaS의 인증 범위는 별도로 살핍니다. 공공 이용의 네 가지 구조, 유형별 평가 항목·점수·절차, 공공 SaaS 가이드와 금융 SLA의 의무는 해당 판본의 원문 확인이 필요합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
제공자보안	시설·서비스 기반 보호	인증 범위·책임 확인
이용자보안	데이터·권한·설정·업무	서비스 모델별경계
보증·계약	측정·감사·사고·종료	통제 실효성·증빙

적용 예제

공공 SaaS 전환 검토

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 민감한 업무 정보를 처리하는 문서 협업 서비스를 도입한다고 가정합니다.

1. 처리하는 정보와 외부 연계 범위, 국외 저장 여부를 확인합니다.

2. 인증서의 서비스명·범위·유효 상태와 별도 보안 검토 요구를 확인합니다.

3. 관리자 권한, 로그 반출, 백업 복원과 계약 종료 시 표준 형식으로 반환하는 절차를 시험합니다.

4. 잔여 위험과 예외를 업무 책임자가 승인하고 재평가 주기를 둡니다.

결과·해석: 기술 검토와 공급자·계약·철수 위험을 한 목록으로 추적합니다.

전제·주의: 이번 조사는 제도 세부 원문을 충분히 확보하지 못했습니다. 일반 설계 예시를 법정 인증 요건 충족으로 사용하면 안 됩니다.

답안 골격과 혼동 방지

도입 수명 주기 → 공유 책임도 → 보안 요소 → CSP 실사·계약 → CSAP 확인 범위

- 제공자 보안 인증을 이용자 준수 전체로 간주하지 않습니다.
- 계약 종료·삭제 증빙을 누락하지 않습니다.

내용을 가리고 회상

1. 서비스 모델이 바뀌면 제공자와 이용자의 책임은 어떻게 달라집니까?

2. 설정을 바꾸는 관리 경로와 실제 데이터 경로를 따로 보호하는 이유는 무엇입니까?

3. 데이터 반환·삭제 절차를 언제 확인합니까?

적용 기준과 근거

일반 보안원리는 설명했으나CSAP 평가 기준·공공SaaS·금융SLA가 이드전문 미열람.해당소요구는 확인필요로유지.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- NIST SP800-145: Definition of Cloud Computing - Peter Mell; Timothy Grance / NIST; 2011-09; 확인 2026-11-05.
- ISMS-P 공식 누리집 - KISA; 2026 표시 페이지; 확인 2026-11-05.